

CompTIA Security+ (SY0-701)

Reorganized Study Notes

Bilingual edition — English/French technical terms with original Arabic explanations preserved

Prepared by Amine

1.0 General Security Concepts

1.1 Security Controls

Control Categories

- **Technical Controls**
 - Implemented through technology (firewalls, antivirus, etc.)
- **Managerial Controls**
 - Security policies, standards, procedures.
- **Operational Controls**
 - Awareness programs, security guards, day-to-day processes.
- **Physical Controls**
 - Limit physical access (guard shacks, fences, locks, badge readers).

Control Types

- **Preventive**
 - Firewall, onboarding policy, guard shack, door lock — stops an incident before it happens.
- **Deterrent**
 - Splash screen, devotion, reception desk, warning signs — discourages an attacker.
- **Detective**
 - System logs, review logs, log review, patrols, motion detection.
- **Corrective**
 - Backup/recovery, policies for reporting issues, contact authorities, fire extinguisher.
- **Compensating**
 - Block instead of a patch, separation of duties, require multiple security staff, power generator.
- **Directive**
 - File storage policies, compliance policies, security policy training, signs reading “Authorized Personnel Only”.

Non-repudiation

- **Non-repudiation = proof of integrity** — توقيع رقمي / هاش — إثبات صحة الرسالة
- **Authentication** — (non-repudiation) التأكد من أن التوقيع ليس مزوراً
- **Digital signature** (signée avec clé privée)

AAA Framework

- **Authentication, Authorization, Accountability**
- Authorization Model components: enrollment, certificate, signed whitelist, private key.

Gap Analysis

- Determine difference with end goal: NIST Special Publication 800-171, ISO/IEC 27001.
- Evaluate people and process; compare and contrast; the final comparison.

Zero Trust

- Something you have (phone)

- Something you know (password)
- Something you are (biometric)

Physical Security

- **Barricades / bollards** — حواجز خرسانية
- **Access control vestibule** — غرفة دخول ذات بابين متتاليين (*mantrap*)
- **Fencing** — سياج
- **Video Surveillance (CCTV)**
- **Guards and access badges**
- **Lighting** (visibility + deterrence)
- **Sensors** — أجهزة استشعار
 - *Infrared* (الأشعة تحت الحمراء)
 - *Microwave* (موجات كهرومغناطيسية قصيرة)
 - *Ultrasonic* (موجات صوتية فوق سمعية)
 - *Pressure* (الضغط) — حساسات ضغط

1.2 CIA Triad

- **Confidentiality** — encryption, access control, two-factor authentication.
- **Integrity** — hashing, digital signatures, certificates, non-repudiation.
- **Availability** — redundancy, fault tolerance, patching.

Deception Technologies

- **Honeypot** — نظام وهمي مصمم لجذب المخترقين (*server/file/network*) وجمع معلومات حول أساليبهم
 - لماذا نستخدمه؟
 - 1. لتضليل خدام مزيف عن النظام الحقيقي
 - 1. المهاجمين يظنون انهم يخترقون النظام الحقيقي
 - 1. سجل النظام يسجل أنشطة وطرق الهجوم
 - 1. الدفاع يستفيد من معرفة طرق وعرض الأنظمة
- **Types: Honeypot, Honeynet, Honeyfile, Honeytoken**
 - *Honeytoken*: ملفات فخ / *Honeyfile*: شبكة كاملة وهمية / *Honeynet*: بيانات أو مفاتيح وهمية

Change Management

- One change in OS → can break thousands of different systems
- صنع تغيير في نظام واحد قد يكسر آلاف الأنظمة المختلفة
- Process for change: update, config, firewall
- توثيق كل تغيير قمنا به

1. Business Process Impacting Security

- **Approval process** — أي تغيير يجب أن يكون عبر موافقة
- **Ownership** — أي تغيير يجب أن يكون عبر شخص مسؤول
- **Stakeholders** — الأشخاص التي عندهم تأثير بالتغيير (*IT, Management, Users*)
- **Impact Analysis** — شئنا حدث (*sys, users*)
- **Test results** — خاص نجرب قبل التأثير الإنتاجي (*production*)

- **Backout plan** — خطة الرجوع إذا وقع مشكل بعد التغيير → *change* فشل
- **Maintenance Window** — وقت معدوم التأثير على المستخدمين (مثلاً ليلاً)
- **SOP (Standard Operating Procedure)** — خطوات واضحة لكل تغيير

2. Technical Implications

- **Allow list / Deny list** — تكون مسموح ضد ممنوع
- **Restricted activities** — حذف الصلاحيات بعد التغيير
- **Downtime** — النظام يتوقف ويتوقف
- **Service restart / App restart** — إعادة تشغيل خدمات بعد تغييرات
- **Legacy application** — أنظمة قديمة
- **Dependencies** — مرتبط مع أنظمة أخرى (*database + app*)

3. Documentation

- **Updating diagrams** — تحديث الرسوم البيانية للشبكة
- **Updating policies / procedures** — تحديث السياسات حسب التغيير

4. Version Control

- **Version control system** — نظام يتابع كل النسخ من الملف (مثال: *config v1, v2* — تتبع التغيير)

Cryptography

Key Escrow

- نسخة احتياطية من المفاتيح يتم الاحتفاظ بها للاسترجاع عند الحاجة

Key Exchange

- **Diffie-Hellman** — طريقة تبادل المفاتيح بين الأطراف بأمان (مثال)
- **Key length** — كل ما كان طويلاً → أمان أكبر

3. Tools

- **TPM (Trusted Platform Module)** — شريحة في الهاردوير، تخزن المفاتيح بأمان
- **HSM (Hardware Security Module)** — جهاز قوي لتخزين المفاتيح، أقوى من *TPM*
- **Key Management System** — إدارة دورة حياة كاملة للمفاتيح
- **Secure Enclave** — منطقة آمنة داخل *CPU*

4. Obfuscation (الدلالة إخفاء)

- **Steganography** — إخفاء معلومات داخل ملف آخر
- **Tokenization** — تبديل البيانات الحساسة برموز (*Token*)
- **Data Masking** — إخفاء جزء من البيانات
 - **Example:** 1234-****-****-****

5-9. Other Cryptographic Concepts

- **Hashing**
- **Salting** — إضافة قيمة عشوائية قبل الـ *hash* لتقوية كلمة المرور
- **Digital Signature** — *proof of identity + integrity*
- **Key Stretching** — زيادة *complexity* لكلمة المرور (مثال: *bcrypt*)

- Blockchain — سجل غير قابل للتغيير

10. Certificates

- CA (Certificate Authority) — جهة موثوقة تصدر الشهادات
- CRL (Certificate Revocation List) — لائحة الشهادات الملغاة
- OCSP — (أسرع من CRL) تتحقق مباشرة من صلاحية الشهادة
- Self-signed vs Third-party — شهادة موثوقة
- Root of Trust — الأساس وراء الثقة
- CSR (Certificate Signing Request) — طلب التوقيع
- Wildcard Certificate — يستخدم لعدة subdomains
— Example: *.google.com

2.0 Threats, Vulnerabilities, and Mitigation

1. Threat Actors

- Nation-state — دول (مثال: روسيا، الصين) — التركيز: التجسس والاستخبارات
- Unskilled attacker — يعتمد على أدوات جاهزة — الهدف: المرح / Fun
- Hacktivist — اختراق بسبب فلسفة سياسية — الهدف: الاحتجاج
- Insider threat — واحد من داخل الشركة — الهدف: المال / الانتقام
- Organized crime — عصابات منظمة — الهدف: الربح المالي
- Shadow IT — موظفون يستخدمون أدوات بدون إذن — خطر بدون قصد

2. Attribute of Threat Actors

- Internal vs External
- Resources / Funding — داخل الشركة وخارجها
- Sophistication — واضح عندو خبرة وأدوات

3. Motivations

- Data exfiltration — سرقة المعلومات
- Espionage — تجسس
- Service disruption (DoS) — تعطيل الخدمة
- Blackmail (ransomware) — ابتزاز
- Financial gain — ربح مالي
- Political belief — انتماء سياسي
- Revenge — انتقام
- Chaos / War — فوضى / حرب

4. Threat Vectors

Message-based

- email → phishing

- SMS → smishing
- Instant Messaging (IM) — WhatsApp, etc.

Image-based

- Malware embedded in images — نوع من الاختراق

File-based

- Virus inside PDF / Word

Voice Call

- Vishing

Removable devices

- Virus via USB

Vulnerable software

- Client-based — التطبيقات التي تثبت على الجهاز
- Agentless — بدون تثبيت (browser-based)

Unsupported systems and apps

- مثال: Windows قديم

Unsecure networks

- Wireless, Wired, Bluetooth — شبكة WiFi غير محمية

Open service ports

- منافذ مفتوحة بدون داعي

Default credentials

- admin/admin

Supply chain

- Managed Service Providers (MSPs) — شركات تدير IT لشركات أخرى — مثال: شركة تدير الـ IT تخترق وتؤثر على الزبائن
- Vendors / Suppliers — شركات تزود بالمعدات والأجهزة (hardware) أو الخدمات السحابية (cloud service)، مثال: Antivirus
- USB device, router, laptop, hardware — المورد: مورد قطع غيار وأجهزة، مثال: المورد

5. Human Vector / Social Engineering

- Phishing
 - عبر email
- Smishing
 - عبر SMS
- Vishing
 - عبر تليفون
- Impersonation
 - التظاهر بأنه (IT, Boss)
- Business Email Compromise (BEC)
 - اختراق ايميل المدير

- **Pretexting**
 - اختراع سيناريو كاذب يقنع الضحية
- **Watering hole**
 - مهاجمة *site* مرتاد كثيراً
- **Brand impersonation**
 - مثال: Amazon / Facebook مزيف
- **Typosquatting**
 - **Example:** *google.com* → *goggle.com*
- **Disinformation / Misinformation**
 - *disinformation* = متعمد، *misinformation* = نشر أخبار كاذبة (غير متعمد)

Cloud / Virtualization / Supply Chain Vulnerabilities

- **Virtualization**
 - VM escape — هروب من VM ودخول إلى *host*
 - Resource reuse — بيانات بقايا في *Disk* أو *RAM*
- **Cloud** — Misconfiguration
- **Supply chain** — *Provider* (software/hardware/خدمة) ما هو آمن
- **Cryptographic encryption** — ضعف
- **Misconfiguration** — *config* (password سهل، port مفتوح) ضعف
- **Mobile**
 - Side loading — تثبيت *app* خارج المتجر الرسمي
 - Jailbreaking — تجريد الحماية
- **Zero day** — ثغرة جديدة مازال ما تم اكتشافها (*vulnerability*)

1. Types of Vulnerabilities

Application

- **Buffer overflow attack** — إدخال بيانات كثيرة → كتابة فوق ذاكرة الكود
- **Memory Injection** — إدخال كود ضمن الذاكرة
- **Race Condition (TOC/TOU)** — اختلاف بين زمن الفحص (*check*) وزمن الاستخدام — فرصة للمهاجم
- **Malicious update** — *Malware* داخل تحديث (*update*)

OS-Based

- (Windows, Linux) — file vulnerabilities

Web-Based

- **SQL injection** — إدخال أوامر ضد قاعدة البيانات (*database*)
- **XSS** — إدخال *scripts* ضد الموقع (*Website*)

Hardware

- **Firmware** — نظام التشغيل الأساسي
- End-of-life / legacy

2. Indicators of Malicious Activity

Malware attacks

- **Ransomware** — تشفير + طلب فدية (data)
- **Trojan** — يبين أنه برنامج عادي وهو موزل
- **Worm** — ينتشر دون تدخل المستخدم
- **Spyware** — يتجسس
- **Virus** — يحتاج لتفعيل من المستخدم
- **Keylogger** — (Keyboard) يسجل ضربات لوحة المفاتيح
- **Rootkit** — يتحكم في النظام بعمق
- **Logic bomb** — ينفجر بشرط معين

Network attacks

- **DDoS**
 - Reflected — المهاجم يرسل طلبات مزيفة باسم الضحية لخدّام آخر، فيرد الخدّام على الضحية
 - Amplified — الرد أكبر من الطلب — حركة مرور أكبر
 - **Example:** (amplified) traffic مضخم → response كبير على الضحية، الخدّام يرد
- **DNS attack** — تخريب نظام تحويل أسماء النطاقات
- **On-path (MITM)** — يقف بين الضحية وبين السيرفر
- **Credential replay** — reuse password.
 - استعمال كلمات دخول (username + password) منسوخة لتسجيل الدخول

Application Attacks

- Injection
- Buffer overflow
- Privilege escalation — user → admin
- Directory traversal — ...//etc/passwd
- Replay attack — استخدام طلب (request) مسجل مرة أخرى
- Forgery — تزوير الطلب (request) باسم attacker
- Replay = إعادة استخدام، Forgery = تزوير

Cryptographic Attacks

- **Downgrade Attack** — المهاجم يجبر النظام على استخدام بروتوكول قديم وأضعف من التشفير
- **Collision Attack** — اثنين مدخلات مختلفة تعطي نفس قيمة ال Hash
 - **Example:** attacker يصنع ملفين مختلفين بنفس قيمة ال hash

Password Attacks

- **Brute Force** — تجريب كل كلمات المرور الممكنة
- **Password Spraying** — تجريب كلمة مرور واحدة شائعة على عدة حسابات

Indicators

- Impossible travel — تسجيل دخول من مدينتين متباعدتين (مثلاً من المغرب وأمريكا في وقت قصير)
- Resource Consumption — CPU usage عالي
- Missing logs
- Account Lockout — حساب محظور بسبب: brute force attack أو password guessing
- Concurrent Session Usage — نفس الحساب داخل أكثر من جهاز ونفس الوقت — أو session زمنياً غريبة

- Blocked Content — منع الوصول لملف أو مجلد
- Resource Inaccessibility — النظام أو الخدمة (system/server) ما عاد قادر يطلع
- Out-of-cycle logging — logs ما في وقت مرتقب
 - **Example:** logs show activity at 3 AM unexpectedly
- Published/Documented — معلومات حساسة نزلت public
- Data breach / leak — تسريب بيانات
- Default password changes — تغيير password الافتراضي

3. Mitigation Techniques

- الأساسيات:
- Segmentation
- ACL — تتحكم بدخول ودخل شبكة معينة
- Least privilege — تعطي مستخدم الصلاحيات الأدنى فقط الكافية لعمله
- حماية الأنظمة:
- Patching — تسديد الثغرات
- Hardening — تخفيض المخاطر (risks)
- Disable ports / services
- Encryption — حماية البيانات
- Monitoring — مراقبة النشاط والتغيرات
- Application allow list — تحديد البرامج المسموح بتشغيلها
- Advanced:
- Isolation — فصل النظام عن الباقي
- Decommissioning — وقف وإزالة النظام
- Endpoint protection / Antivirus / Firewall / HIPS
- Host-based Firewall — جدار حماية يستخدم داخل نفس الجهاز (PC/Server)
- HIPS (Host-based Intrusion Prevention System) — نظام يراقب الجهاز ويمنع العمليات المشبوهة
- HIPS يحلل البرامج

3.0 Security Architecture

3.1 Architecture Models

1. Cloud

- Responsibility Matrix (Shared Responsibility)
- Infra (hardware/datacenter) — مسؤولية cloud provider
- Data + access + config — مسؤولية you (customer)
 - **Example:** Saas المستخدم مسؤول عن Data، غير مسؤول عن البنية التحتية

Cloud Service Models

- SaaS (Software as a Service) — مثال: Gmail, Google Docs, Microsoft 365
 - بروفائدر يتحكم بكل شيء، المستخدم يسجل دخول ويستعمل من المتصفح فقط

- PaaS (Platform as a Service) — *(functions)* يدير التطبيقات *Client*، يقدم البنية، *Client* بروفائدر يقدم البنية،
- IaaS (Infrastructure as a Service) — *sys* المستخدم مسؤول عن *hardware, network, power & cooling*؛ *hardware, network, power & cooling* بروفائدر يقدم *security update*, الحساب، البيانات

2. Infrastructure Models

- IaC (Infrastructure as Code) — *deployment* أتمتة كود، *deployment* تكوين البنية التحتية كأكواد، *deployment*
 - *Vulnerabilities* خطأ في كود = خطر كبير على
- Serverless — *(Functions)* *client* يكتب الكود فقط، *Provider* يدير كل البنية التحتية، *Provider*
 - *dependency* على *provider* مخاطر:
- Microservices — *التطبيق* مقسم لخدمات صغيرة مستقلة
 - *API* هجمات: مخاطر
- Hybrid — Cloud + on-prem mix
 - *complexity + misconfiguration* خطر:
- Third-party vendors — *supply chain attack* خطر:
 - *contracts + security controls* الحل:

3. Network Infrastructure

- Physical Isolation — *(hardware)* فصل فيزيائي
- Air-gapped — *high security (military, banking)* يستخدم في (لا إنترنت ولا اتصال خارجي)؛ يستخدم في
- Logical Segmentation — *limit lateral* (attacker جانبياً) *network: VLANs / Firewalls* تقسيم الهدف: الحد من حركة (movement)

SDN (Software-Defined Networking)

- *network* نموذج حيث نتحكم في كل الشبكة من مكان واحد (*centralized*)
- Control plane — اتخاذ القرارات
- Data plane — تمرير البيانات
- التحكم كامل بكل دور من *Controller* عوضاً عن كل *switch/router* يوسع *config* محلياً

4. Deployment Models

- On-premises — *(full control)* كل شيء عندك
- Centralized vs decentralized — *control* مركزي vs موزع

5. Virtualization & Containers

- Virtualization — VM (Virtual Machine)
 - *VM escape* خطر:
- Containerization — *(Docker)* لا تحتاج OS كامل
 - *Container* = نظام مشترك (*Kernel*) لكن منعزل

6. Specialized Systems

- IoT (Internet of Things) — *cameras, smart devices* أجهزة:
 - *(no updates)* بدون تحديثات، ضعيف أمني،
- ICS / SCADA — *(vulnerable)* ثغرات، أنظمة تحكم صناعي،
 - *(industrial control systems)* يستخدم ICS: التحكم في المعدات الصناعية
 - *SCADA*: نظام إشراف وجمع بيانات (*Supervisory Control and Data Acquisition*) — نوع من ICS

- **RTOS (Real-Time OS)** — نظام تشغيل سريع محدد ووحيد المهمة، يستخدم في *devices* مثل السيارات، الإنسان الآلي، الطائرات بدون طيار
- **Embedded Systems** — أجهزة كاملة داخل *devices* أخرى (مثلاً ماكينة بنكية ترتبط بكمبيوتر داخل جهاز آخر)

7. High Availability

- 7/24 — نظام يبقى متاح دائماً
- Redundancy, failover, load balancing techniques
- *Service ID Primary / Backup Server*

8. Important Considerations

- Availability — النظام متاح ويمكن الوصول إليه
- Resilience — القدرة على الصمود أمام الهجمات
- Cost — تكلفة *Cloud* أو غيرها
- Responsiveness — سرعة الرد
- Scalability — قابلية التوسع
- Ease of deployment — سهولة النشر وتفعيل النظام
- Risk Transference — نقل الخطر (مثلاً *Insurance* أو *Cloud*)
- Ease of recovery — *backup + disaster recovery*
- Patch availability — توفر التحديثات (*updates*)
- Inability to patch — أنظمة (*IoT, ICS*) ما عندها *update*
- Power — المصدر الذي يوفر الطاقة (الكهرباء) للسيرفر، الراوتر، *Cloud*
- Compute — الذاكرة وموارد المعالجة
- هي الموارد التي يحتاجها السيرفر (*processing power, RAM*) ويوزع تحمل

2. Failure Modes

- Fail-open — (غير آمن) عادي ينظم حتى مع وجود خطأ
- Fail-closed — (أكثر أماناً) عادي يوقف كامل عند وجود خطأ

3. Device Attributes

- **Active / Passive**
- Active — يتدخل في حركة مرور (*IP traffic*)
 - **Example: IPS**
- Passive — يراقب بدون تدخل
 - **Example: IDS — Inline / Monitor (Tap)**
- Inline — كل دورة المرور *traffic* تعدي من خلاله
 - **Example: IPS**
- Tap — نسخة من *Traffic* غير مباشرة
 - **Example: IDS**

4. Network Appliances

- **Jump Server (Bastion Host)** — بوابة دخول وسط (*server jump server (admin access only)*) نظام محدد
- **Proxy Server** — وسيط بين *user* والإنترنت — يفلتر المحتوى (*filter content*) ويخفي *IP*
- **IDS / IPS**

- *IDS*: يكتشف فقط (*detect*)
- *IPS*: يكتشف ويمنع (*detect + block*)
- **Load Balancer** — *availability* يحسن، *DDoS* مقاومة على *servers*، يوزع *traffic* على عدة *servers*

5. Authentication & Access Control

- **Port Security** — *switch* من *port* بكل جهاز يتصل
- **Example: Allow Only 1 Mac Address**
- **802.1x / IEEE**
- **Network Access Control (NAC)** — *نظام يتأكد من حالة الجهاز (Device) قبل دخوله للشبكة*

Authentication Process (Supplicant / Authenticator / Auth Server)

- 1. Supplicant — *الجهاز (PC/phone)*
- 2. Authenticator — *Switch يمرر بيانات المصادقة*
- Authentication Server — *RADIUS Server (Remote Authentication Dial-In User Service)*
- AAA → Access / Deny

EAP (Extensible Authentication Protocol)

- *Framework* لبروتوكولات المصادقة *authentication*، يدعم عدة طرق (*Methods*) ويسمح بإضافة *authentication* جديدة كل ما نريد
- Options:
 - EAP-TLS — *certificate* يستخدم
 - PEAP — *tunnel* داخِل
 - EAP-TTLS / TLS Tunnel / Auth

6. Firewalls

- **WAF (Web App Firewall)**
 - *web apps* يحمي — *sql injection* ضد
- **UTM (Unified Threat Management)**
 - *firewall + antivirus + IPS/IDS* يجمع — *(small companies)* في جهاز واحد
- **NGFW (Next Generation Firewall)** — *(deep packet inspection)* يفحص الحزم بعمق
- Layer 4 vs Layer 7 — *(Port/IP) vs (HTTP, DNS, FTP app data)*
 - *src IP, dest IP, port* من سرعة تحقق
 - *sé, NGFW أو Deep Packet Inspection (DPI), Content* — *محتوى Request/طلب*

7. Secure Communication / Access

- **VPN** — *(remote workers)* يستخدم للعمل عن بعد
- **Remote Access** — *(MFA + VPN)* دخول النظام بأمان
- **Tunneling** — *(encapsulation)* تغليف الحركة (*traffic*) داخل بروتوكول آخر
- **TLS** — *(HTTPS)* تشفير الويب — *حماية البيانات أثناء النقل*
- **IPSec** — *اتصال شبكة آمن*

8. Modern Network Architecture

- **SD-WAN (Software-Defined Wide Area Network)** — *centralized* (مركزي) ربط فروع الشركة عبر الإنترنت بـ تحكم مركزي (Routing)، توجيه ذكي (control)
- **SASE (Secure Access Service Edge)** — *VPN + Firewall + Zero Trust* تجمع cloud؛ خدمة شبكة وأمان في cloud؛

9. Selection of Effective Controls

- اختيار آلية أمان مناسبة حسب كل حالة
 - **Example:** Attack: web app hacking → WAF
 - **Example:** Unauthorized network access → 802.1X
 - **Example:** Performance issue → Load Balancer
 - **Example:** Remote Workers → VPN + MFA

1. Data Classification

- Sensitive — *مثل دسمو ,email, IDs, CNIC*
- Confidential — *business secrets.*
- Restricted — *لازم يبقى سري (military, secrets)*
- Critical — *downtime = disaster*

3. Data Considerations

Data States

- Data at rest — *data stored (DB)*
- Data in transit — *data moving*
- Data in use — *data being processed (RAM)*

Data Sovereignty

- البيانات تابعة لقوانين البلد اللي تخزن فيه — *الدول*

Geolocation

- Server / Datacenter — *location*
- *Compliance* data sovereignty — *privacy laws* تعتمد على البلد

4. Methods to Secure Data

- **Geographic Restriction** — *تحديد من وين يمكن الوصول*
- **Encryption** — *تحويل البيانات داخل Rest و in Transit*
- **Hashing** — *One-way function (passwords)*
- **Masking** — *إخفاء جزء من البيانات*
 - **Example:** 1234-****-****
- **Tokenization** — *تبدیل بيانات حساسة برمز عشوائي (token)*
 - **Example:** Card number → random token
- **Obfuscation** — *إخفاء الدلالة، تشويش بيانات حساسة*

Resilience and Recovery

Segmentation

- Data/Network segmentation — *limitation* تقسيم وتحديد
- Permission restrictions — *access control* (who can see what)

1. High Availability

- **Load Balancing** — توزيع *traffic* بين *servers*
- **Clustering** — *distribution + redundancy* جوهر: مجموعة *servers* تعمل بدور واحد
- $LB = distribution / Cluster = unity + redundancy$

2. Site Considerations

- نختار *site* الاحتياطي بناءً على الميزانية والوقت الذي نحتاجه
- **Hot Site** — *downtime (immediate failover required)* تقريباً بدون *server, data, network* جاهز ومدمج 100%
- **Warm Site** — نص جاهز، بيانات + *hardware* موجودة، لكن سيكون وقت قبل التشغيل الكامل (*balance* بين *cost* و *speed* و *downtime*)
- **Cold Site** — موقع فارغ بدون *data, server* ولا شيء — يحتاج وقت طويل للتجهيز
- **Geographic Dispersion** — خادم / مركز بيانات في أكثر من موقع جغرافي (مدن أو دول مختلفة) — تجنب *impact* كارثة واحدة (الزلازل، الحريق، انقطاع الكهرباء)

3. Platform Diversity

- استخدام أنظمة مختلفة (*Windows + Linux*) — تجنب *single point of failure*
- Multi-Cloud Systems — استخدام أكثر من *cloud provider*
 - **Example:** AWS + Azure

4. Continuity of Operation (COOP)

- خطة تضمن استمرارية العمل حتى أثناء الكوارث

5. Capacity Planning

- People
- Technology
- Infrastructure — *datacenters, servers, software, network*
- *Load* — يجب نخطط مسبقاً

6. Testing

- **Table top exercise** — المراقبة كأنها سيناريو هجوم/كارثة، بدون أي تأثير حقيقي على النظام
 - **Example:** “discussion-based / no real sys impact” = table top
- **Failover test** — اختبار الانتقال من السيرفر الرئيسي (*primary*) إلى *Backup* عند توقف
 - **Example:** “test switching to backup system” = failover test
- **Simulation Test** — اختبار واقعي في بيئة معزولة (بحاكي مشكلة سيناريو)
 - **Example:** “realistic test without affecting production” = simulation

- **Parallel Processing** — تشغيل البيانات القديمة والجديدة معاً تزامناً — تكلفة أكبر برأس مال موارد
 - **Example:** “run old and new sys simultaneously” = parallel processing

7. Backups

- **Onsite Backup** — تخزين Backup داخل نفس مكان الشركة
 - نقص: لو حصل كارثة بنفس المكان (data center نفس server) ال backup يضيع أيضاً
 - **Example:** “fast recovery needed but same location” = onsite backup
- **Offsite Backups** — تخزين في موقع مختلف
 - **Example:** “protect data from natural disaster” = offsite backup
- **Frequency** — daily / weekly / real-time
- **Encryption** — حماية Backup
- **Snapshots** — نسخة سريعة من الحالة الكاملة (caps)

Recovery Methods

- Replication — نسخ data real-time بين servers
- Journaling — تسجيل كل تغيير بشكل تدريجي (يسهل الرجوع)

8. Power Protection

- **UPS (Uninterruptible Power Supply)** — مزودة من طاقة احتياطية أثناء انقطاع الكهرباء (battery)
- **Generator** — مصدر طاقة احتياطية أكبر — مدتها أطول
- **Journaling/event logging** = تسجيل الأحداث؛ يستخدم لنسخ الرسائل من المرسل/المستلم (email retention/compliance/legal) (hold/archive)

4.0 Security Operations

1. Secure Baselines

- **standard** آمن لكل جهاز
- **Establish** — إنشاء T config — port closed, services inutiles → OFF, password policy قوية
- **Deploy** — تطبيق نفس ال config على كل الأجهزة (PC/server)
- **Maintain** — الحفاظ — patching, monitoring, auditing
- **baseline = reference** الأمن، وأي انحراف (deviation) عنه يعتبر دخول غير مصرح (unauthorized)

2. Hardening Targets

- Workstation — antivirus, firewall
- Mobile — Encryption + PIN
- Router / Switch — disable unused ports
- Cloud — Identity and Access Management
 - Users/Identities — تكوين عدد المستخدمين
 - Permissions / Access — نشر وتوزيع
- Least privilege

- Servers — patching + logging
- ICS / SCADA — Isolation (critical systems)
- IoT / Embedded / RTOS — minimal services

3. Wireless Devices

- **Site Survey (Planning)** — *WiFi (Access Points) دراسة المكان قبل تركيب*
 - *(Access Points) تحديد عدد نقاط الدخول*
 - *coverage تقييم العوائق (حواجز/أبواب) من 3 طوابق وتأثيرها على*
 - *(interference) تجريب التداخل مع شبكات أخرى*
 - **Example:** *شركة عندها 3 طوابق — كل طابق يحتاج Access Point وتحديد وضعية + قوة الـ signal للتغطية الكاملة*
- **Heat Map** — *visualization (visual map) — كثافة 'إشارة Signal' أحمر = قوي، أصفر = متوسط، أخضر = ضعيف*

4. Mobile Solutions

- **MDM (Mobile Device Management)** — *إدارة الأجهزة عن بعد*
 - Remote Wipe — *مسح البيانات عن بعد عند فقد الجهاز*
 - Full Wipe — *مسح كامل*
 - Selective Wipe — *مسح بيانات الشركة فقط*
- Enforce policies — *فرض قوانين على الأجهزة المسجلة*
- Track devices (GPS) — *تتبع موقع الجهاز عند فقدانه*

Deployment Models

- BYOD (Bring Your Own Device) — *جهاز خاص يستخدمه الموظف في الشركة*
- COPE (Corporate Owned, Personally Enabled) — *جهاز الشركة، يستعمله الموظف*
- CYOD (Choose Your Own Device) — *اختيار من قائمة معتمدة (approved)*

Connection Methods

- Cellular (4G/5G) — *أكثر أماناً*
 - *Attack: SIM swapping*
- WiFi — *خطر اختراق Access Point*
- Bluetooth — *(short range) إشارة قصيرة المدى، ثغرات بسبب القرب*

5. Wireless Security Settings

- **WPA3** — *تشفير WiFi الأقوى*
- **RADIUS (AAA)** — *Auth, Authorization, Accounting*
- **Crypto Protocols** — *TLS / AES*
- **Auth Protocols** — *EAP / PEAP*

6. Application Security

- **Input validation** — *منع SQLi, XSS*
- **Secure Cookies** — *HttpOnly — منع وصول JavaScript للكوكيز*
- **Static Code Analysis** — *تحليل الكود بدون تشغيل*
- **Code Signing** — *التأكد ما تم التعديل على البرنامج*

7. Sandboxing

- تشغيل برنامج في بيئة معزولة (*controlled environment*)
 - **Example:** فتح ملف مشبوه بمكان آمن قبل النظام الفعلي

8. Monitoring

- مراقبة: *logs, traffic, behavior*
- Tools: SIEM, IDS/IPS

1. Acquisition / Procurement Process

- يعني كل قرار شراء (شركة تشتري أدوات أو برامج) يبدأ من تحليل: هل ماتشترى أي حاجة فعلاً نحتاجها؟ (*Do we really need it?*)
- الاحتياط: *security requirements, contract + licensing*

2. Assignment / Accounting

- يعني ربط كل *asset* بمسؤول معين
- Ownership — كل جهاز يصير عنده *owner* واحد
- Classification — تحديد حساسية الجهاز/البيانات: *Public, Confidential, Secret*

3. Monitoring / Asset Tracking

- Inventory — قائمة كاملة بالأجهزة والبرامج، تشمل الأجهزة وتراخيص *software*
- Enumeration — تفصيل وفهرسة كل *asset* — *parts installed, OS version*
 - “detailed information gathering” = enumeration
- Tracking — متابعة كل الأجهزة وانتقالها واستعمالها

4. Disposal / Decommissioning

- يعني عملية الإخراج لجهاز انتهت صلاحيته
- Sanitization — مسح البيانات بشكل آمن قبل ما نستغني عنه
 - Overwrite — الكتابة فوق البيانات القديمة ببيانات جديدة عشوائية
 - Factory Reset — رجوع الجهاز لحالة المصنع
 - حذف *user data + settings* المستخدمة
- Destruction — تدمير فيزيائي (*physical*)
 - HDD shredding — تكسير
 - تفكيك الأجهزة لأجزاء صغيرة
- Certification — وثيقة رسمية 'تأكيد' تثبت أن البيانات تم مسحها بشكل آمن
- Data Retention — مدة الاحتفاظ بالبيانات — (*compliance/policy*) حسب السياسة والشركة

Vulnerability Management

1. Identification Methods

- Vulnerability scan — سريع، آلي (*automated*)، أقل دقة من البنتستينج، يولد لائحة بالثغرات (*vulnerability list*)
 - Tools: OpenVas, Nessus
- Pentesting أعمق — يستهدف فعلاً ويستفيد من الثغرات؛ ينتج *downtime* أكثر

Application Security

- Static Analysis (SAST) — تحليل الكود بدون تشغيله
 - Keyword: “early in development”, “without executing code”
- Dynamic Analysis (DAST) — تشغيل التطبيق ومراقبة السلوك أثناء التشغيل
 - بدون الوصول لكود المصدر — Keyword: “Runtime”, “black-box testing”
- Package monitoring — الفكرة الأساسية: التطبيق الحديث يعتمد كثيراً على *third-party libraries/dependencies*؛ مراجعة المكتبات المستخدمة (مثال: *python* في *pip*)
 - Keywords: “third-party libraries”, “dependencies”, “open-source components”, “software supply chain”

Threat Feeds (الأمنية المعلومات مصادر)

- OSINT — معلومات علنية ومتوفرة عامة
 - **Example:** GitHub, forums, Google
 - Keywords: “free intelligence”, “public source”, “open-source data”
- Proprietary / Third-party Feeds — معلومات مدفوعة من مزودين متخصصين
 - **Example:** FireEye, CrowdStrike
 - Keywords: “paid feeds”, “subscription-based”, “commercial threat intelligence”
- Information-sharing Organizations — منظمات وكيانات تشارك بيانات حول هجمات
 - **Example:** ISAC (Information Sharing and Analysis Center)
- Dark Web — جزء من الإنترنت مخفي به بيانات مسروقة: *leaks, credentials*

Penetration Testing

- *hacking* — اختراق أخلاقي
 - Keyword: “exploit”, “active attack”
- Responsible Disclosure Program — شركة تسمح لـ *security researcher* بدخول النظام واختباره وتبليغ بطريقة قانونية
 - Keywords: “report vulnerabilities responsibly”, “notify the company”, “coordinated disclosure”
- Bug Bounty Program — الشركة تدفع للباحثين الذين يكتشفون الثغرات ويبلغون عنها
 - Keywords: “reward”, “payment”, “financial incentive”

System / Process Audit

- مراجعة وتدقيق السياسات (*policies*) والإجراءات (*configurations*)
- هل الشركة ملتزمة بقواعد ومعايير محددة (*Standards/Compliance*)؟ تحليل إداري + تقني معاً
 - Keywords: “review policies”, “check compliance”, “configuration review”, “audit logs/procedures”

2. Analysis (الثغرات تحليل)

Confirmation

- هل الثغرة مؤكدة أم لا؟ (*verify vulnerability / validate finding*)
- False positive — تم الإبلاغ ولكنها غير حقيقية
- False negative — ثغرة فعلية لم يتم اكتشافها

Prioritize

- من نبدأ نتعامل أولاً مع الثغرات؟ — حسب: *severity, impact, risk*
- CVSS (Common Vulnerability Scoring System) — نظام تقييم خطورة الثغرة من 0 إلى 10
 - **Example:** Critical = 9.8, High = 7.5, Medium = 4.0, Low = 1.2

- Keywords: “severity score”, “0 to 10 rating”

CVE (Common Vulnerabilities and Exposures)

- معرف فريد ID لكل ثغرة (unique identifier)
 - **Example:** CVE-2014-1234, CVE-2013-9876
 - Keywords: “unique identifier for vulnerability”

Vulnerability Classification

- نوع الثغرة
- SQL injection, XSS, buffer overflow, privilege escalation
 - Keyword: “type of vulnerability”

Exposure Factor

- نسبة معدل الضرر (% attack) عند حدوثه
 - **Example:** System compromise: 70% loss, data leak: 40% loss

Environmental Variables

- تأثير الثغرة يختلف حسب البيئة environment
 - **Example:** Vulnerability test system → impact ضعيف، production كبير → impact

Industry / Organizational Impact

- Business case — هل الثغرة تؤثر على بنك (Critical) أو app اختبار (low impact)?
 - **Example:** Bank system → critical / test app → low impact

Risk Tolerance

- الفكرة: مدى استعداد الشركة لتقبل الخطر (risk)
 - شركة strict — تأخذ مدخل صارم من risk
 - شركة قادرة تأخذ مدخل أقل صرامة

3. Vulnerability Response & Remediation

- **Patching** — تحديث النظام والتطبيقات لسد الثغرة
- OS update, software update, security patch
 - Keywords: “apply update”, “fix vulnerability”, “install security update”
- **Insurance** — الشركة تدفع تأمين ضد cyber attacks
 - **Example:** Data breach وقع، الشركة تستلم تعويض من insurance
 - Keyword: “financial protection”, “coverage for cyber incidents”
- **Segmentation** — تقسيم الشركة لأجزاء أصغر — تحديد
 - Keywords: “limit lateral movement”, “contain attack”
- **Compensating Controls** — حل مؤقت بدلاً من إصلاح الثغرة مباشرة
 - Keywords: “temporary solution”, “workaround”, “alternative control”
- **Exception / Exemption** — الشركة تقرر تقبل بعض المخاطر (risk) ولكن توثقه
 - **Example:** نظام Software قديم، تم الموافقة عليه ولكن موثق رسمياً
 - Keywords: “risk accepted”, “not fixed due to business needs”

4. Validation of Remediation

- Rescanning — نعاود فحص ثغرة
- Audit — مراجعة
- Verification — تأكد رسمي إن المشكلة تم حلها

5. Reporting

- تقارير العملية الإدارية
- Vulnerabilities
- Risk
- Actions
- الملخص يكون واضح ولغة عملية (business + clear language)

Monitoring & Detection

1. Monitoring Computing Resources

- Systems — server, end-points (PCs), Windows/Linux machines
- Application — Web apps, databases, APIs
 - errors, unusual behavior, login attempts
- Infrastructure — network devices (routers/switches), firewalls, cloud resources
 - نشوف وين الحركة الشاذة وشكل خدمة باستمرار، ونلاحظ attack حالات

2. Activities (المراقبة أنشطة)

- Log Aggregation — جمع كل logs من عدة مصادر في مكان واحد
 - **Example:** Server + firewall + app → SIEM
 - Keywords: “centralized logs”
- Alerting — نظام يدفع تنبيه عند ملاحظة حالة مشبوهة
 - **Example:** multiple failed logins, malware detected
- Scanning — فحص دوري للأنظمة
 - **Example:** Vulnerability scan, Port scan
- Reporting — تقارير للإدارة
- Incidents, risks, status
- Archiving — تخزين logs القديمة
 - J forensics و compliance قانوني

3. Alert Response & Remediation

- Quarantine — عزل البرنامج الخبيث
 - **Example:** عزل PC المصاب بـ virus
 - Keyword: “isolate infected system”
- Alert tuning (balance) — ضبط نظام التنبيهات (alerts) للحد من التنبيهات الكثيرة (noise)
 - **Example:** balance بين sensitivity وعدد alerts
 - Keywords: “reduce false positives”, “too many alerts”, “noise reduction”, “improve alert accuracy”

4. Tools (الكشف أدوات)

- **SCAP (Security Content Automation Protocol)** — *standard* معيار موحد
 - Vulnerability scanning
 - Compliance checking
 - *Keywords: “automated compliance”, “standardized security checks”* — SCAP = automation + compliance
- **Benchmarks** — أدلة الإعدادات المعيارية (*config guidelines*) لكل نظام، مرجع آمن
 - *Keywords: “secure configuration standard”, “baseline configuration”*

Agent vs Agentless

- **Agent-based** — برنامج يُثبت على الجهاز
- **Agentless** — *network remote scan* بدون تثبيت
- Agent → Installed on system / Agentless → no installation/remote
- **SIEM (Security Information and Event Management)** — *logs + events + alerting* تجميع
 - *Keywords: “centralized logging”, “event correlation”, “real-time monitoring”*
- **Antivirus** — *malware/viruses* اكتشاف وإزالة
 - *Keyword: “detect and remove malware”*
- **DLP (Data Loss Prevention)** — منع تسريب البيانات الحساسة
 - *Keywords: “prevent data exfiltration”, “protect sensitive data”*
- **SNMP (Simple Network Management Protocol)** — *network devices: router, switch, server* بروتوكول يدير
 - **SNMP Traps** — الجهاز يرسل تنبيه (*Alert*) آلياً لو حدث شيء غير عادي
 - *Keywords: “device sends alert automatically”, “unsolicited alert”, “notification from network device”*
- **Netflow** — مراقبة *traffic* الشبكة
 - *Source, destination, traffic flow*
 - *Keywords: “analyze network traffic patterns”*
- **Vulnerability Scanners** — أدوات فحص الثغرات
 - **Example: Nessus, OpenVas**
 - **Example: ports** مفتوحة بدون داعٍ تكتشف
 - *Exam keyword: security prevention*
- **Security Groups** — *ports/protocols* — (*Firewall*) (دخول/خروج) — *Inbound/Outbound* قواعد جدار الحماية
 - **Example: ports** حظر باقي الـ *allow port 80 (HTTP), allow port 443 (HTTPS)*
 - *vs Security Group (resource level — VM, port) Network Firewall (داخل الشبكة) الفرق:*
 - *Keywords: “cloud firewall”, “control traffic to VM”, “allow specific ports”*

5. Ticket Creation

- *alert* نظام إنشاء *ticket* عند ظهور
 - **Example: alert → ticket: Incident response**

Escalation

- رفع المشكلة لمستوى أعلى عند عدم القدرة على الحل
 - *Exam Tip: SLA*

Firewall

- **Rules** — Allow/Deny traffic
- **Access Lists (ACLs)** — (IP/Network) تتحكم بدخول وخروج
- **Ports/Protocols** — HTTP (unsafe) = 80, HTTPS (secure) = 443
- **DMZ** — منطقة وسط بين internal network والإنترنت — Screened Subnets
 - Web servers, public services
 - Keywords: public-facing server → DMZ, restricted traffic → Firewall rules

IDS / IPS

- **Signatures** — أنماط هجوم (attack pattern)
- **Trends** — behavior analysis (anomalies)
 - Keywords: “detect only” → IDS, “block attack” → IPS

Web Filter

- يراقب ويمنع الوصول لمواقع ضارة
- Phishing sites, malware, social media
- Category-based filtering
- Block social media sites
- **Block rules** — قوائم مواقع تم منع التسبب فيها
 - **Example:** block facebook.com, block youtube.com
 - Keyword: “explicit deny rule”, “block specific URL”
- **Reputation** — تصنيف المواقع
 - trusted ✓ / suspicious Δ / malicious X
 - (database) reputation قواعد بيانات
 - Keyword: “site reputation”, “trusted vs malicious”, “reputation score”
- **Agent-based filtering** — برنامج صغير يثبت على endpoint (works on device حتى خارج الشبكة)
 - Keywords: “installed on endpoint”, “works outside network”, “per-device control”
- **Centralized Proxy** — كل request المستخدم يمر من server واحد مركزي
 - filtering يصير في مكان واحد (proxy server, single control point)
 - Keywords: “centralized filtering”, “proxy server”, “single control point”
- **URL Scanning** — فحص الرابط قبل الوصول
 - Check: malware, phishing, suspicious patterns
 - Keywords: “scan URL before access”, “check link safety”
- **Content Categorization** — تصنيف المواقع حسب النوع
 - social media, adult content, gaming, news
 - block social media — المدمج: المزامنة دخول، Keywords

4. Operating System Security

- إعدادات: users, permission, system settings — لازم نحافظ عليها كل الأقسام
- **Group Policy (Windows)** — أداة تتحكم في إعدادات لكل المستخدمين بشكل مركزي
 - **Example:** password policy، منع USB، فرض
 - Keywords: “centralized management”, “enforce policies on users”, “Windows domain policy”
- **SELinux (Linux)** — نموذج أمني security model، تحكم بكيفية الوصول access

- يتحكم النظام كاملاً — *Keyword: "Mandatory Access Control (MAC)"*

5. Secure Protocols

- Protocol Selection HTTP بدل Telnet، HTTPS بدل SSH —
- Port Selection اختيار port مناسب —
- Transport Method — TCP vs UDP
 - *Keywords: "secure remote access" → SSH، "encrypted web" → HTTPS*

6. DNS Filtering

- Block malicious domains

7. Email Security

- **SPF (Sender Policy Framework)** — يتحقق من أن email جاء فعلاً من domain المرسل
 - تكوينه عبر *record DNS*
 - *Keyword: "verify sender", "authorized mail server"*
- **DKIM (Domain Keys Identified Mail)** — توقيع رقمي للإيميل، يثبت سلامة (integrity) الرسالة (msg) ولم يتم العبث بها
 - يستخدم *Cryptography*
- **DMARC** — سياسة تجمع نتائج *SPF + DKIM* وتحدد ماذا نفعل
 - reject, quarantine, report
 - *Keywords: "policy enforcement", "what to do if SPF/DKIM fail", "reporting"*
- **Email Security Gateway** — نظام يفحص كل email يدخل النظام
 - spam filtering, phishing blocking, malware detection

8. File Integrity Monitoring

- يراقب الملفات (files) وأي تغيير يحدث → نظام الملف يبدل alert

9. DLP

- منع تسرب البيانات (data)
 - *Example: Credit card → Block: block employees uploading credit card numbers*

10. NAC (Network Access Control)

- يحدد أجهزة *compliant* غير المسموحة بالدخول
 - *Example: منع PC مادخلت activities → منع دخول*

11. EDR / XDR

- **EDR (Endpoint Detection and Response)** — مراقبة *endpoint (PC) — based on behavioral analysis (Component-based analysis)*
- **XDR (Extended Detection and Response)** — متقدم: *endpoint + network + cloud*
- *Exam:*
 - "detect advanced threats → endpoint" = EDR
 - "integrated detection across systems" = XDR
- **UBA (User Behavior Analytics)** — مراقبة سلوك المستخدم وتحديد ما يخالف السلوك الطبيعي (normal behavior)

- *login* غير معتاد، ساعة غير معتادة، استخدام غير معتاد

Identity and Access Management (IAM)

1. Provisioning / De-provisioning

- **Provisioning** — إنشاء حساب *user + permissions*
 - **Example:** *email + access* → موظف جديد
- **De-provisioning** — حذف أو تعطيل كامل الحساب
 - يجب أن يتم فوراً *access* الموظف الذي ترك الشركة
 - *Keywords: "risk ex-employee access" → deprovisioning, "immediate disabling"*

2. Permission Assignments

- الصلاحيات تتحدد حسب الدور (*job role*) في النظام
 - **Example:** *IT — settings (admin)*، *HR — يستطيعون دخول موظفين*
- RBAC — Role-Based Access Control (User-based, Group-based)
- Privilege Creep — تراكم صلاحيات مع الوقت (موظف يبقى عنده *access* قديم وزائد عن حاجته/*over-privileged*)

3. Identity Proofing

- التأكد من هوية الشخص قبل منحه *access*
 - **Example:** *face verification + وطنية*
 - *Impersonation*: الخطر

4. Federation

- ربط هويات بين منظمات مختلفة (*organizations*)
 - **Example:** *login* بحساب *Google* لموقع آخر *site*
 - *Keywords: trust between organizations → federation*

5. SSO + Protocols

- **SSO (Single Sign-On)** — دخول *login* مرة واحدة لكل الخدمات (*service*)
 - **Example:** *Outlook + Microsoft Teams* بـ *Login* *Microsoft* يفتح كل أداة مباشرة
 - الهدف: تجربة مستخدم أفضل (*user experience*)
 - *Password* واحد → أقل *risk* للنسيان
 - الخطر: لو *attacker* دخل حساب واحد → اخترق كل الحسابات
 - الحل: استخدام *MFA*
- **LDAP (Lightweight Directory Access Protocol)** — بروتوكول لإدارة *directory* (مستخدمين *Users*) — قاعدة بيانات *Directory*
 - Users, Passwords, Groups, Permission
 - **Example:** *Active Directory*
 - *Authentication + lookup dual users*
 - *Keywords: "centralized user database", "directory service"*

- **OAuth** — *password* مشاركة بدون *app access* يعطي — *Authorization* فقط (*authentication*)
 - *login with facebook* — كرسمين الدخول، اختصار *email* وباسوورد
 - *face* يعطي *OAuth permission* هو *authentication* لكن
 - *Keywords: API access, third-party apps, delegation*
- **SAML (Security Assertion Markup Language)** — *SSO authentication* في *Protocol* يستخدم
 - تبادل *login info* عبر *exchange* (الموثقات بين الأطراف)
 - Identity Provider (IdP), Service Provider (SP)
 - **Example:** *assertion token (Adsertion)*، *login* يد 2. *SAML* دخل *user* (1). *Enterprise* (المؤسسات) — كاتش كاتب (1). *user* دخل *service* من *login* آخر (3)
 - *Keywords: enterprise SSO + xml-based + federated SAML*

6. Interoperability

- أنظمة مختلفة تقدر تشتغل وتتواصل مع بعضها (*cross-platform*)
- معايير (*Standards*) — *XML, JSON*
- بروتوكولات (*Protocols*) — *SAML, OAuth*
 - *Keywords: compatibility between systems, working together, cross-platform communication*

7. Attestation

- إثبات أن *permission* معينة لا زالت صالحة (*valid*)
 - **Example:** *manager* يراجع كشف صلاحيات *access* الموظف، ويأكد إذا كانت لا زال محتاجها

8. Access Controls

- **Mandatory Access Control (MAC)** — *access* (government) من له يحدد النظام نفسه من له
 - **Example:** (*classified data*) — *strict ACL* مصنفه
 - *Keywords: government, classified data, strict ACL*
- **Discretionary Access Control (DAC)** — *access* من له يقرر من له *Owner*
 - **Example:** *Windows file owner*
- **Role-Based Access Control (RBAC)** — *access* حسب *Role* (الدور)
 - **Example:** *HR — employee level access, Admin — IT access*
 - *Keywords: job role, department*
- **Rule-based Access Control** — *access* حسب قواعد (*rules*) محددة
 - **Example:** *firewall rule: block port 80, allow IP*
 - *Keywords: firewall, ACL (Access Control List), rules*
- **Attribute-Based Access Control (ABAC)** — *access* حسب *attributes* متعددة
 - location, device, time, role
 - **Example:** *الموظف يدخل من جهاز الشركة فقط ووقت العمل*
 - *Keywords: multiple condition, context-aware, location/device*
- **Time-Based Access Control** — *access* حسب وقت محدد
 - **Example:** (*business hours*) *VPN* فقط من 5-9
 - *Keywords: time restriction, business hours*

Principle of Least Privilege

- كل *user* يأخذ أقل صلاحية يحتاجها فقط لعمله
 - **Example:** *user* باريوز يقدر *access* فقط لما يحتاجه
 - *Keywords: too many permissions, reduce risk, limit access*

9. Multi-Factor Authentication (MFA)

Factors

- Something you know → password
- Something you have → phone
- Something you are → fingerprint
- Somewhere you are → location

Types

- Biometrics
- Tokens
- Security Keys

10. Password Concepts

Best Practices

- Length, Complexity
- No reuse
- Expiration — (انتهاء)
- Age

Tools

- Password Manager
- Passwordless
- *modern solution* الحل العصري = *passwordless* — *complexity* مهم، *Keywords: length*

11. Privileged Access Management (PAM)

- Just-in-time access — منح صلاحيات مؤقتة عند الحاجة فقط
- Password Vault — تخزين كلمات مرور آمن
- Ephemeral credentials — بيانات اعتماد مؤقتة، تنتهي بسرعة
- *Keywords: admin access*, مؤقت، محدود

Automation and Orchestration

- **Automation** — تشغيل *task* واحدة أو سكريبت *tasks* تلقائياً
 - **Example:** *script* ينظف *user*
- **Orchestration** — تنسيق بين عدة أدوات *Automation* معاً
 - **Example:** *account access* واحدة → *log* → *access ticket* — *Automation = task* → *user* يسجل
 - *Workflow/Orchestration* = عدة *tasks* مرتبطة

- (proof tracking) incident متابعة = (record) ticket سجل = log + ticket: log

1. Use Cases of Automation & Scripting

- **User provisioning** — إنشاء حسابات user تلقائياً
 - **Example:** HR يضيف موظف → script ينشئ account تلقائياً
 - Keywords: IAM, Identity and Access Management
- **Resource provisioning** — إنشاء server/cloud resources تلقائياً
 - **Example:** auto deploy VM
 - Keywords: cloud environment
 - **Example:** script: Server محتاج VM ينشئ، محدد IP
- **Guard rails** — قواعد تمنع misconfiguration
 - **Example:** منع port مفتوح بشكل خاطئ
 - Exam Keywords: security prevention
- **Security groups** — قواعد Firewall لكل VM
 - Inbound / Outbound
 - Ports / Protocols
 - **Example:** allow port 80 (HTTP), allow port 443 (HTTPS), block باقي ال ports
 - الفرق: Network Firewall (لكن الشبكة) vs Security Group (Resource level — VM, وحدة)
 - Keywords: “cloud firewall”, “control traffic to VM”, “allow specific ports”
- **Ticket Creation** — نظام ينشئ ticket تلقائياً
 - **Example:** alert → ticket: Incident Response

Escalation

- رفع مستوى المشكلة لشخص أعلى
 - **Example:** Incident لم يحل خلال 15 دقيقة → escalation مع manager
 - Escalation = رفع المستوى للمسؤول الأعلى ولكن من غير ما يفوت ال deadline
 - Exam Tip: SLA

Enable / Disable Service Access

- تشغيل/إيقاف access للمستخدمين
 - **Example:** disable account: موظف غادر الشركة
 - Exam Tip: السريع = حماية فورية لما تتسرب

Continuous Integration & Testing (CI/CD)

- Continuous Integration
- Continuous Delivery / Continuous Deployment
- test + deploy تلقائي
 - **Example:** Workflow كامل: code dev → CI: build, test → CD: deploy automatic

Exam Tip

- DevSecOps — يدخل security في كل مرحلة
 - **Example:** security check قبل deploy، deploy قبل deploy
 - Keywords: automated testing, auto-deploy, pipeline

APIs (Application Programming Interfaces)

- ربط أنظمة *Systems* مع بعضها
 - **Example:** *SIEM* يرسل *log* إلى *Firewall*
 - *Exam Tip:* tools integration

2. Benefits of Automation

- Efficiency / Time Saving — سرعة *manual* أبطأ
- Enforcing baselines — نفس *config* على كل الأجهزة (*servers, settings*)
 - *Tip:* consistency
- Standard Configuration — *infra* موحدة، *to reduce errors*
- Scaling Securely — هل ممكن نزيد *systems* بأمان؟
 - *Tip:* cloud + automation = scalable
- Employee retention — تقليل *stress, workload*، زيادة *productivity*
 - *Exam Tip:* reduce workload, improve efficiency, reduce repetitive tasks
- Reaction time — رد سريع — *attack* → *auto block*
- Workforce multiplier — *user* واحد يعمل أكثر — زيادة *productivity*

3. Other Considerations (Risks)

- Complexity — *automation* كبير *complexity* في *setup*
- Cost — *tools, budget* تكلفة
- Single Point of Failure — لو *automation* عطل، كل النظام عطل
- Technical debt — حل قديم متراكم، يحتاج صيانة (*maintenance*)
- Ongoing Support — متابعة دائمة، “*set and forget*” خطأ

Incident Response

- Incident Response — عملية منظمة للتعامل مع (*security incident (attack, breach, malware)*)
- الخطوات سهلة تقنية ومنظمة

Incident Response Lifecycle (المراحل)

- 1. Preparation — التحضير قبل ما يصير أي *incident*
 - Policies, Tools (SIEM, etc.), Training, Backup plans
 - الوقاية = *prevention + readiness*
- 2. Detection — اكتشاف أن *attack* حدث أو وقع
 - **Example:** *SIEM alert: unusual login, malware detected*
 - “something suspicious happened” = Detection
- 3. Analysis — تحديد نوع الحادث
 - **Example:** *severity* — تحديد *insider threat? ransomware? phishing*
- 4. Containment — تقليل انتشار الحادث
 - **Example:** *disconnect PC, isolate network*

- goal = stop damage
- **5. Eradication** — تنظيف الجذر والسبب
 - **Example:** remove malware, patch vulnerability
 - “cleaning phase”
- **6. Recovery** — إعادة النظام لحالته الطبيعية
 - **Example:** restore backups, bring systems online
 - verify sys is safe
- **7. Lessons learned** — تحليل ما حصل للتحسين المستقبلي
 - **Example:** why attack happened? how to improve?
 - continuous improvement

2. Training

- تدريب فريق الأمن (security team)
 - **Example:** phishing awareness, incident drills
 - هدف: تقليل human factor

3. Testing (الاختبار)

- **Table Top Exercise** — نقاش وسيناريو تطبيقي simulation/discussion
 - فريق يناقش سيناريوهات هجوم، بدون أي تأثير على أنظمة حقيقية
 - Tip: no real systems
- **Simulation** — اختبار وأفعال واقعي test
 - **Example:** (real environment but controlled) attack simulated على system تجريبي

4. Root Cause Analysis (RCA)

- نبحث عن السبب الحقيقي خلف الحادث
 - **Example:** exploit vuln, weak password
 - “why did it happen”

5. Threat Hunting

- نبحث active عن تهديدات (threats) مخفية وغير معروفة
 - **Example:** (reactive مو) detection — proactive attacker داخل النظام قبل

6. Digital Forensics

- جمع وتحليل الأدلة (evidence) قانونياً ودقيقاً بحيث ندافع عن الحقيقة وراء الجريمة (المجرم) بشكل قانوني
- المهم: تحليل الجريمة + تحديد الجاني بطريقة قانونية لتقديمها للمحكمة

Legal Hold

- منع حذف أو تغيير البيانات حال كان هناك قضية (مادي أو قانوني)
 - court وتقدمها لا “important for court cases”
 - “No Modification / integrity”

Chain of Custody

- تتبع الدليل (evidence): مبن شاف، مبن قام بنسخ، مبن تعامل مع الدليل
 - Keywords: evidence tracking / history

Acquisition

- جمع الأدلة
 - **Example:** copy of hard disk, logs of server, memory dump
 - طريقة جمع الأدلة (forensic copy/طريقة جامدة)
 - Keywords: collect evidence / copy data

Reporting

- كتابة تقرير دقيق فيه:
- شرح ووقع الحادث
- كيفية وضع الأدلة
- النتائج
- الأدلة
 - Keywords: Documentation / Findings

Preservation

- الحفاظ على كل الأدلة دون تغيير
- Data integrity
- Search in critical evidence

E-discovery

- جمع قانوني من داخل البيانات وأرشفتها
- Email, Files, Messages
 - **Example:** "lawsuits — "legal search in data قضايا

Data Sources for Investigations

1. Firewall log data

- **Firewall logs** — (ports blocked/allowed) تسجيل كل الحركة الخارجة الداخلة
 - **Example:** IP, Firewall logs = network traffic control مستوى block
- **Application logs** — logs دياول البرامج
 - **Example:** app داخل login failed, error
 - application log → الاستثناء/إنذار
- **Endpoint logs** — logs دياول الأجهزة (PC, laptop)
 - **Example:** antivirus alert, usb plugged
 - "device-level activity"
- **OS-specific security logs** — Windows/Linux دياول logs
 - **Example:** login attempts, privilege change
 - System events + security events
- **IPS / IDS logs** — attack detected

- Intrusion detection
- **Network logs** — حركة الشبكة *traffic*
 - **Example:** DNS queries, connections between devices
 - Network behavior analysis
- **Metadata** — data عن data
 - **Example:** file created time, sender email info, file size
 - useful for forensics (مفيدة)

2. Data Sources

- **Vulnerability Scans** — Scan يكتشف Weakness
 - **Example:** outdated software, open ports
 - can be exploited تعرف وين
- **Automated reports** — reports generated automatically
 - **Example:** weekly security report, SIEM report
 - quick overview of sys health
- **Dashboards** — real-time visualization
 - **Example:** SIEM dashboard (Splunk, etc.) — monitoring live activity
- **Packet Captures (PCAP)** — تسجيل كل حركة الشبكة (capture network traffic)
 - **Example:** Wireshark capture
 - deepest level of investigation

5.0 Security Program Management and Oversight

1. Security Governance

- (Security Program Management & Oversight) — الجهة المسؤولة عن إدارة الأمن والمعلومات داخل الشركة
- القوانين الداخلية، المسؤوليات، القرارات
- إدارة المخاطر + مسؤوليات + مراقبة الأنظمة

A. Guidelines vs Policies vs Standards

1. Guidelines

- إرشادات/توصيات — ما شيء مفروض إلزاماً
 - **Example:** ينصح بأن نستخدم كلمات سرية مزنة
- Guidelines = recommendations / Policies = Mandatory

2. Policies

- قوانين إلزامية داخل الشركة
- **Acceptable Use Policy (AUP)** — تحديد ما يسمح وما يمنع استخدامه من أجهزة الشركة
 - **Example:** browsing ممنوع تصفح شخصي زائد، malware ممنوع تحميل، piracy ممنوع
- **Information Security Policies** — قوانين عامة حول إدارة المعلومات
 - **Example:** MFA إلزامي، exception إذا، passwords سياسة متكاملة

- **Business Continuity** — كيف الشركة تبقى تقدم خدمة استمرارية حتى مع وقوع كارثة
 - **Example:** إذا حصل خلل بمركز البيانات، الشركة تنقل تشغيلها لمكان آخر
 - “keep business running”
- **Disaster Recovery (DR)** — خطط ترجيع الأنظمة بعد كارثة
 - Restore backups, rebuild servers
- *business continuity = نظام يبقى يشتغل بشكل مستمر؛ disaster recovery = ترجيع system*
- **Incident Response** — *incident (attack, breach, malware)* خطة تنظيمية ديال كيفية الرد على
 - 1. Preparation
 - 2. Detection
 - 3. Containment
 - 4. Eradication
 - 5. Recovery
 - 6. Lessons learned
- **SDLC (Software Development Life Cycle)** — كيف نصنع software منظمة وآمنة من البداية
 - كل ما تطور software لازم نراعي security
- **Change Management** — أي تغيير يجب أن يمر عبر *approval + testing* قبل ما يطبق على system في *production*

3. Standards

- قواعد تقنية محددة يلزم تطبيقها
- **Password Standards** — *minimum 12 chars, complexity*
- **Access Control Standards** — تحديد من يقدر يدخل لشئو
 - **Example:** *least privilege, RBAC*
- **Physical Security Standards** — حماية موقع الشركة
 - Cameras, badge access, locks
- **Encryption Standards** — نوع التشفير المستخدم
 - **Example:** *AES-256, TLS 1.3*

4. Procedures

- خطوات عملية بالتفصيل
 - Policy: “backups”
 - Procedure: “backup step by step” — كأنها خطوات (steps) تفصيلية

Onboarding / Offboarding

- **Onboarding** — عند دخول موظف جديد
 - Account creation, permissions, badge
- **Offboarding** — عند خروج موظف
 - Disable account, remove access, collect laptop
- لازم يكون *access* الموظف الذي ترك يلغى مباشرة — *offboarding failure* = خطر

Playbooks

- دليل (guide) جاهز خطوة بخطوة للحالات (incidents) محددة
 - **Example:** *ransomware playbook, phishing playbook*

5. External Considerations

- قوانين خارجية (Regulatory) تؤثر على الشركة سواء كانت محلية أو دولية
- **Regulatory** — قوانين تنظم الشركة
 - **Example:** GDPR, HIPAA
- **Legal** — أمور قانونية عامة
- **Industry** — متطلبات المجال
 - **Example:** banking, healthcare
- **Local / National / Global** — القوانين تختلف من بلد لآخر، قوانين محلية/بلدية/دولة/إقليمية/دولية
 - سياسات الشركة تتنازل وتراعي قوانين كل دولة منطقة عاملة فيها

6. Monitoring and Revision

- مراجعة وتحديث *policies* دورياً حسب التهديدات الجديدة (*new threats*)

7. Governance Structures

- **Board** — مجلس إدارة يدير الرؤية العليا للشركة
- **Committees** — مجموعة من الأقسام والإدارات وقوانين أكثر تفصيلاً
- **Government Entities** — هيئات حكومية ينظم القطاع
- Centralized vs Decentralized:
 - Centralized — كل القرارات من مكان واحد، إدارة وتحكم أسهل (*easier control*)
 - Decentralized — توزيع الإدارة حسب الأقسام (*flexibility*)، أكبر (*department management*)
 - لكن أقل *consistency* — يجب توحيد الإدارة (*standard*) ودمج الأفكار

8. Roles and Responsibilities

- **Owner** — صاحب البيانات/النظام — هو من يقرر:
 - من له access، تصنيف (classification)
 - Owner = decision maker
- **Controller** — يقرر كيفية استعمال البيانات
 - **Example:** GDPR — الشركة تحدد عدة بيانات وعملية لمعالجتها
- **Processor** — ينفذ المعالجة بناءً على *instructions* من الـ Controller
 - **Example:** Cloud provider — Processor = executing processor

الأدوار ملخص

- Role → Description
- Owner — يقرر شئو يستخدم وتوزيع/تصنيف
- Controller — يقرر كيف يتم استخدام البيانات
- Processor — ينفذ على البيانات حسب تعليمات الـ Controller
- **Custodian / Steward** — مسؤول تقنياً (*technically*) عن حماية البيانات
 - backups, storage, permission
 - Custodian = technical caretaker

B. Risk Management

- عملية تحديد، تقييم، والتعامل مع المخاطر ($Risk = Threats \times Vulnerability$)

1. Risk Identification

- تحديد الخطر
- Ransomware, Insider threat, Floods

2. Risk Assessment

- Ad hoc — تقييم غير منتظم (مثلاً لما حدث *accident*)
- One time — تقييم مرة واحدة
- Recurring — تقييم كل فترة
- Continuous — تقييم طوال الوقت

3. Risk Analysis

- Qualitative — تحليل بالكلمات (وصفي)
 - High, Medium, Low
- Quantitative — تحليل بالأرقام والمعادلات الرياضية

SLE: Single Loss Expectancy

- الخسارة من حادثة واحدة

$SLE = Asset Value \times Exposure Factor$

- $Asset Value = \text{قيمة الأصل}$
- **Example:** $SLE = 5000\$ \rightarrow \text{الضرر } 50\% \text{ , } \$10000 \text{ يساوي Server}$

ARO: Annual Rate of Occurrence

- مرات وقوع الحادثة في السنة
- **Example:** $ARO = 2 \rightarrow \text{مرتين في السنة}$

ALE: Annualized Loss Expectancy

- الخسارة السنوية

$ALE = SLE \times ARO$

- **Example:** $SLE = 5000\$ \text{ , } ARO = 2 \rightarrow ALE = 10000\$$

Value of insurance decision (ALS vs Mec)

- $ALE \times ACS$ مقارنة — $ACS = \text{repenser le coût annuel des solutions de sécurité / insurance}$

Probability / Likelihood

- احتمال وقوع الخطر

Impact

- حجم الضرر الأكبر

4. Risk Register

- وثيقة تجمع كل *risks* وتحتوي:
- Risk owner

- Impact
- Mitigation

Key Risk Indicators (KRI)

- مؤشرات تبين الخطر
 - **Example:** *failed logins* زيادة

Risk Owners

- الشخص المسؤول عن المخاطر (المسؤول عن مراقبة risk)

Risk Threshold

- النقطة التي عندها الخطر (risk) يعتبر غير مقبول

5. Risk Tolerance

- مدى تحمل الشركة قادرة تتحمل risk معين

6. Risk Appetite

- **Expansionary** — تتقبل risks بزيادة
- **Conservative** — *risks* تتجنب
- **Neutral** — وسط

7. Risk Management Strategies

- **Transfer** — تنقل risk لجهة أخرى
 - **Example:** *insurance*
- **Accept** — تقبل ال risk كما هو
 - **Example:** *cost* الحل أكبر من *cost* الخطر
- **Avoid** — تتجنب الخطر بالكامل
 - **Example:** *service* خطير توقف
- **Mitigate** — تقلل ال risk
 - **Example:** *firewall, MFA, patching*
- **Exception / Exemption** — استثناء، الموافقة على عدم تطبيق *policy/rule* لفترة معينة (مدة محدد)
 - **Example:** *exception* لكن *exception* تم منحه لجهاز IT واحد ولكن *exception* موثق رسمياً، وبعد المدة *exception* يبطل، يستثنى *Data*

8. Risk Reporting

- الإبلاغ عن المخاطر للإدارة (*reports*)

9. Business Impact Analysis (BIA)

- تحديد أهمية الأنظمة *critical systems*
- تحديد *downtime* المقبول
- *Risk Exploitation: utiliser un risque pour obtenir un avantage*

RTO: Recovery Time Objective

- الوقت المسموح خلاله النظام يرجع يخدم

RTO = Maximum Acceptable Downtime

- **Example:** "2 ساعات server يجب يرجع خلالها"

RPO: Recovery Point Objective

- أقصى كمية data نقدر نخسرها

RPO = Maximum Acceptable Data Loss

- **Example:** $RPO = 1h \rightarrow$ backup كل ساعة

MTTR: Mean Time to Repair

- متوسط وقت الإصلاح

MTBF: Mean Time Between Failures

- متوسط الوقت بين الأعطال

C. Third-Party Risk Assessment and Management

- $Third-party =$ أي شركة خارجية نستخدمها معها
 - **Example:** Cloud provider, Payment Company, MSP, SaaS provider
- الخطر الأساسي: ضعف security عند vendor يقدر يؤثر علينا، نقطة ضعف weak point

1. Vendor Assessment

- تقييم Vendor قبل التعامل معاه
- **Penetration Testing** — اختبار اختراق Pentest يطلب باستضافة من security ديال vendor
 - $compatible - vendor scare \rightarrow penetration testing$ غير
- **Right-to-Audit Clause** — بند داخل عقد يسمح بمراجعة وتدقيق ديال vendor
 - يعني "عندنا الحق نراجع نديري tender vendor"
- **Evidence of Internal Audits** — vendor يوريك تقاريره الداخلية
 - لإثبات أنهم Compliance ملتزمين
- **Independent Assessments** — تقييم من جهة مستقلة
 - **Example:** SOC 2 audit
 - أقوى من self-assessment
- **Supply Chain Analysis** — تحليل كامل لسلسلة التوريد ديال vendor
 - كن attack عند مورد supplier ممكن يضرنا
 - **Example:** SolarWinds attack مثال مشهور

2. Vendor Selection

- كيفاش نختار vendor مناسب
- **Due Diligence** — البحث والتدقيق قبل التعاقد
 - Reputation, Security, Compliance, History

Conflict of Interest

- تضارب المصالح
 - **Example:** *manager* اختار *company* وقد يكون له علاقة شخصية بها — يهدد *fairness* القرار
- WO (Work Order) — كل مهمة محددة
- SOW (Statement of Work) — *deliverable*، التكلفة، الوقت، نطاق الخدمة، تحدد: نطاق الخدمة، الوقت، التكلفة، *deliverable*
 - “define project scope” = SOW

3. Agreement Types

- كل وثيقة عندها *acronyms* محددة نزاع
- SLA (Service-Level Agreement) — يحدد مستوى الخدمة
 - **Example:** *uptime 99.9%, response time*
- MOA (Memorandum of Agreement) — اتفاق رسمي بين جهتين حول خدمات
 - يحدد المسؤوليات والبيانات
- MOU (Memorandum of Understanding) — تفاهم غير رسمي أكثر بنية التعاون
 - *MOA* أنزل رسمية من *MOU*
- MSA (Master Service Agreement) — عقد عمل طويل المدى
 - يحدد القواعد العامة للخدمة، كل *project* قد يكون له اتفاق خاص
- NDA (Non-Disclosure Agreement) — اتفاقية سرية
 - ممنوع نشر المعلومات
- BPA (Business Partners Agreement) — اتفاق بين شركات لأجل التعامل
 - *responsibilities / security requirements* يحدد

4. Vendor Monitoring

- متابعة دائمة للالتزام *Compliance* ديار *vendor*
 - **Example:** *audits, security reviews, performance checks*

5. Questionnaires

- استبيانات أمنية تستوفيها *vendor*
 - **Example:** هل *MFA* مفعل؟ هل *data encrypted*؟

6. Rules of Engagement (ROE)

- القواعد قبل *pentest* أو *audit*
- نطاق محدد (scope)، الوقت، *scope* الأنظمة المسموح اختبارها

D. Security Compliance

- *Compliance* = الالتزام بالقوانين والأنظمة

1. Compliance Reporting

- Internal — تقارير داخل الشركة

- management
- **External** — تقارير للجهات الخارجية
 - regulators, auditors, government

2. Consequences of Non-Compliance

- **Fines** — غرامات مالية
 - **Example:** GDPR fines
- **Sanctions** — عقوبات تنظيمية
- **Reputational Damage** — ضرر السمعة — الناس ما عاد يثقون بالشركة
- **Loss of License** — إمكانية إيقاف الشركة عن العمل
- **Contractual Impacts** — تأثير تجديد العقود مع الشركاء/ *Contracts*

3. Compliance Monitoring

- **Due Diligence** — التحقق قبل
- **Due Care** — اتخاذ الحماية اللازمة وكفائتها
- **Attestation** — تصريح رسمي — أكد إن النظام *Compliant*
- **Acknowledgement** — تأكيد إن الموظف اطلع على *policy* ووافق عليها
 - **Example:** *AUP* يوقع *employee* على
- **Internal and External Monitoring** — مراجعة داخل المنظمة وخارجها
- **Automation** — استخدام *tools* متابعة *compliance* بشكل *automatic*
 - **Example:** *Continuous compliance scanning*

4. Privacy

- حماية البيانات الشخصية
- **Legal Implications** — *Local / Regional / National / Global*
- **Data Subject** — الشخص الذي تخصه *data*
 - **Example:** الزبون
- **Controller** — كيف يقرر ويحدد كيفية استخدام *data*
- **Processor** — ينفذ معالجة البيانات حسب تعليمات الـ *Controller*
 - **Example:** *Cloud provider*
- **Ownership** — من يملك *data*
- **Data Inventory and Retention** — تحديد بيانات تتدخل في *data* وتحديد مدة مدى ووقت مزينة (نظام)
- **Right to be Forgotten** — حق الشخص بطلب حذف *data* ديالو
 - مشهور مع *GDPR*

E. Audits and Assessments

- كفاءة الشركة تراجع كراجع نفسها وديارها — تتكون كثير من أنواع *audit* و *pentest*

1. Attestation

- تصريح رسمي دبال شي حاجة — *document* رسمياً

2. Internal Audits

- مراجعات داخلية — تتم داخل إدارة الشركة
- **Self Assessment** — (*audit + compliance + governance*) الشركة كاتراجع تنظيمها بنفسها
 - *external audit* من *credibility* أزرج نوعية أقل

3. External audits

- مراجعات من جهة خارجية — أكثر *credibility*
- **Regulatory** — *regulator* من الحكومة أو
 - **Example:** *bank regulator*
- **Examination** — فحص رسمي للأنظمة/البرامج (*Systems/Processes*)
- **Assessment** — تقييم عام للأمان
- **Independent Third-party audit** — شركة مستقلة كاتراجع كل أمور *security*

4. Pentesting

- **Physical Pentest** — اختبار الحماية الفيزيائية
 - **Example:** *tailgating*، محاولة دخول المبنى،
- **Offensive** — الهجوم المحاكى للأدوار *attacker*
- **Defensive** — المراقبة والدفاع وكشف ووقف الهجوم
- **Integrated** — خليط من *defensive* و *offensive*، تدريب *people team* أو سيناريو
- **Known Environment** — *White Box Testing* — المهاجم عارف بالأدلة (المعلومات) كاملة
- **Partially Known Environment** — *Gray Box* — عنده معلومات محدودة
- **Unknown Environment** — *Black Box* — المهاجم ماعارف والو، زي *attacker* حقيقي

Reconnaissance

- **Passive Recon** — جمع المعلومات بدون تفاعل مباشر
 - **Example:** *LinkedIn, Google, social media* — كيفية البحث
- **Active Recon** — تفاعل مباشر مع *target*
 - **Example:** *port scanning, ping sweep* — ممكن تتكشف

F. Security Awareness Practices

- “البشر اضعف حلقة في الأمن”

1. Phishing

- محاولة خداع المستخدم
- **Phishing Campaigns** — حملات تدريبية، الشركة تصنع *phishing* مزيف عشان تختبر الموظفين
- **Recognizing a Phishing Attempt** — كيف نكتشف *phishing*
 - Urgent language
 - Spelling mistakes

- Fake links
- Attachments — مشبوهة
- **Responding to suspicious Message** — ماذا نفعل عند الشك
 - Report message
 - Notify security team

2. Anomalous Behavior Recognition

- التعرف على السلوك غير الطبيعي
- **Risky** — سلوك فيه risk
 - **Example:** الموظف يستخدم USB غير مصرح
- **Unexpected** — نشاط غير متوقع
 - **Example:** login في 3 صباحاً
- **Unintentional** — خطأ غير متعمد
 - **Example:** الموظف يرسل data بالخطأ

3. User Guidance and Training

- **Policy / Handbook** — documents تشرح القوانين المستندة
- **Situational Awareness** — الوعي بما يحيط بالمحيط (الو محيطه)
 - **Example:** يتنبه شخص غريب داخل الشركة
- **Insider Threat** — الخطر من داخل الشركة
 - Malicious, Careless employee
- **Password Management** — Best practices
 - MFA, Strong passwords, Password Manager
- **Removable Media and Cables** — مخاطر الوسائط القابلة للنقل والكابلات
 - USB attacks, malicious charging cable
- **Social Engineering** — التلاعب بالبشر
- أنواع:
 - Phishing
 - Tailgating
 - Pretexting
- **Operational Security (OPSEC)** — حماية المعلومات الحساسة اليومية
 - **Example:** ما نشارك معلومات داخلية على social media
 - Hide badges
- **Hybrid / Remote Work Environments** — مخاطر العمل عن بعد
 - Insecure WiFi
 - Shoulder surfing
 - Shared device

Solutions

- MFA
- VPN
- Screen lock

4. Reporting and Monitoring

- Initial training — تدريب أولي عند بداية الموظف
- Recurring training — تدريب متكرر دوري

5. Development

- Security Awareness Program — إنشاء وبناء برنامج توعية
- Policies
- Training materials
- Planning

6. Execution

- تطبيق البرامج فعلياً
 - **Example:** Phishing simulation, employee training

End of Notes

These notes cover the full SY0-701 Security+ objectives across all five domains: General Security Concepts, Threats/Vulnerabilities/Mitigations, Security Architecture, Security Operations, and Security Program Management. All original Arabic explanations have been preserved alongside the reorganized English/French technical content.